

PR02 – 01 El eslabón más débil:
diseño ético de una campaña de ingeniería social.

Edgar Omar Rodriguez Hernandez

177888

Seguridad Informática.

UPSLP

Mtro. Servando López Contreras.

Marco teórico

Durante mucho tiempo, la seguridad informática se enfocó principalmente en proteger el perímetro de los sistemas, utilizando herramientas como firewalls, antivirus o sistemas de prevención de intrusiones (IPS). Sin embargo, con el paso del tiempo se ha visto que muchos ataques no entran por fallas técnicas, sino a través de las personas. Por eso surge el concepto de **Human Risk Management (HRM)**, que se enfoca en entender que los usuarios suelen ser el objetivo principal de los atacantes actuales.

La ingeniería social es una de las técnicas más utilizadas para lograrlo. En lugar de explotar una vulnerabilidad del sistema, los atacantes buscan aprovechar la forma en que las personas toman decisiones. En muchos casos utilizan ciertos estímulos psicológicos para provocar una reacción rápida del usuario. Por ejemplo, pueden generar **urgencia** con mensajes como “su cuenta será suspendida en 2 horas”, aparentar **autoridad** enviando correos que parecen venir del director de la empresa o del área de TI, o provocar **curiosidad o miedo** mediante avisos de multas, paquetes retenidos o actividades sospechosas en una cuenta.

Para entrenar a los usuarios y reducir este tipo de riesgos, algunas organizaciones utilizan simulaciones de phishing. Una simulación bien diseñada intenta parecer lo más cercana posible a un ataque real. Primero, puede incluir **suplantación de identidad (spoofing)**, usando dominios muy parecidos a los originales o modificando ciertos encabezados de correo para que el mensaje parezca legítimo. Después, en lugar de utilizar software malicioso, se emplean elementos seguros llamados **beacons o balizas**, que solo registran si el usuario hizo clic en el enlace sin afectar su equipo. Finalmente, cuando el usuario interactúa con el mensaje, aparece una página informativa que explica qué señales de alerta pasaron desapercibidas, aprovechando el momento para reforzar el aprendizaje.

Fundamentación técnica

Métricas

Para evaluar la efectividad de una plataforma, no basta con saber quién hizo clic. En 2026, las métricas se dividen en reactivas y proactivas:

- **Click Rate (o Phish-Prone Percentage - PPP):** Mide la vulnerabilidad bruta. El promedio global para organizaciones no entrenadas es del **33.1% al 34.3%**, aunque los ataques con IA han elevado esta cifra hasta el **54%** en sectores vulnerables.
- **Reporting Rate (Tasa de Reporte):** Es considerada la "métrica estrella" o condición de victoria. Mide cuántos usuarios utilizan el botón de alerta. Un programa maduro debe aspirar a una tasa superior al **30%**.
- **Time-to-Report (o Dwell Time):** Cuantifica la velocidad de respuesta del usuario. En 2026, el tiempo promedio de clic es de apenas **21 segundos**, por lo que un reporte rápido es vital para que el SOC pueda contener la amenaza.

- **Risk Score (o Human Risk Score):** Una métrica compuesta que pondera el comportamiento histórico (clics, reportes y cursos terminados) para identificar qué departamentos o individuos necesitan mayor protección.

Enfoques de entrenamiento

Las plataformas que se analizaron utilizan diferentes estrategias para intentar cambiar el comportamiento de los usuarios frente a ataques como el phishing. En general, se pueden identificar cuatro enfoques principales.

El primero es el **enfoque adaptativo o basado en inteligencia artificial**, utilizado por plataformas como Hoxhunt y Phished. En este caso, el sistema analiza cómo responde cada usuario a las simulaciones y, con base en su desempeño, ajusta la dificultad de los siguientes ejercicios. De esta manera, el entrenamiento se vuelve más personalizado y progresivo.

Otro enfoque es el **basado en storytelling o narrativa emocional**, como el que utiliza NINJIO. Esta plataforma utiliza pequeños episodios con estilo cinematográfico para explicar situaciones de seguridad informática. La idea es que, al conectar las historias con situaciones cotidianas o personales, los usuarios recuerden mejor los conceptos y los apliquen en su trabajo.

También existe el **enfoque de cumplimiento y bibliotecas de contenido**, presente en plataformas como KnowBe4 y Infosec IQ. Estas soluciones ofrecen grandes catálogos de cursos y materiales sobre distintos temas de ciberseguridad. Su objetivo principal es ayudar a las organizaciones a capacitar a muchos empleados al mismo tiempo y cumplir con estándares o normativas como ISO o NIST.

Por último, algunas plataformas aplican un **enfoque basado en roles**, también presente en Infosec IQ. En este caso, el contenido se adapta al tipo de trabajo de cada persona dentro de la empresa. Por ejemplo, los desarrolladores pueden recibir ejercicios relacionados con código seguro, mientras que el personal de contabilidad podría enfrentar simulaciones de fraude en facturas o correos financieros. Esto hace que el entrenamiento sea más relevante para cada área.

Diferencias técnicas reales

Arquitectura manual o basada en librerías

Plataformas: KnowBe4, Infosec IQ.

Funcionamiento: En este modelo el administrador tiene que encargarse de la mayor parte del proceso. Debe elegir las plantillas de simulación, definir las fechas de envío y organizar a los usuarios en distintos grupos de manera manual.

Ventaja: Permite tener un control bastante claro sobre el contenido que se envía y el momento en que se realizan las campañas.

Arquitectura autónoma o IA-Native

Plataformas: Phished, Hoxhunt.

Funcionamiento: En este caso la plataforma funciona de forma mucho más automatizada. No es necesario programar campañas manualmente, ya que el sistema utiliza inteligencia artificial para decidir cuándo enviar las simulaciones y qué tipo de prueba es más adecuada para cada usuario.

Ventaja: Reduce mucho la carga de trabajo para los administradores y evita enviar correos de entrenamiento masivos a toda la empresa al mismo tiempo, lo que ayuda a disminuir la fatiga del usuario.

Arquitectura integrada al gateway o al SOC

Plataformas: Proofpoint, Mimecast, Cofense.

Funcionamiento: Estas soluciones se integran directamente con el flujo de correo de la organización. Plataformas como Proofpoint y Mimecast utilizan información de amenazas reales para generar simulaciones de phishing que imitan ataques que están ocurriendo en ese momento. En el caso de Cofense, el enfoque se centra más en el análisis de los reportes que envían los usuarios, los cuales se canalizan directamente hacia procesos de análisis forense.

Ventaja: El entrenamiento se basa en amenazas reales que ya están afectando a la organización, lo que hace que las simulaciones sean más relevantes y realistas.

Análisis

1. KnowBe4: El Ecosistema de Escala Masiva

KnowBe4 se posiciona como el estándar de la industria por su volumen. Su arquitectura se basa en el **KMSAT (Kevin Mitnick Security Awareness Training)**.

- **Diferenciador Técnico:** Su herramienta **PhishFlip** permite tomar un correo de phishing real que haya llegado a la organización y convertirlo automáticamente en una simulación segura para el resto de los empleados en minutos.
- **Enfoque de Entrenamiento:** Basado en la cantidad y variedad. Su **ModStore** funciona como un "Netflix de seguridad" con contenido en más de 34 idiomas y diversos estilos, desde micro-módulos hasta series de alta producción.
- **Métricas de Medición:** Utiliza el **Phish-prone Percentage (PPP)**, que mide la probabilidad de que un grupo caiga en un ataque, permitiendo comparativas (benchmarking) contra empresas del mismo sector.
- **Control Ético:** Permite la **segmentación granular**, evitando que empleados que ya demostraron competencia sigan recibiendo pruebas básicas, lo que previene la fatiga y el resentimiento del usuario.

2. Hoxhunt: El Motor de IA Adaptativa

Hoxhunt rompe con el modelo de "campañas mensuales" para pasar a un modelo de **entrenamiento individualizado**.

- **Diferenciador Técnico:** Utiliza **IA Agéntica** para ajustar la dificultad de cada correo de forma dinámica. Si un usuario falla, el siguiente correo es más sencillo; si acierta, la sofisticación aumenta progresivamente.
- **Enfoque de Entrenamiento:** Gamificación pura. Los usuarios no son "probados", sino que participan en un juego global donde ganan estrellas y suben en rankings al reportar simulaciones.
- **Métricas de Medición:** Se enfoca en el **Dwell Time** (tiempo que tarda un usuario en reportar) y la capacidad de detectar amenazas reales, no solo simuladas. El 60% de sus usuarios reporta al menos una amenaza real en su primer año.
- **Control Ético:** Filosofía de **Refuerzo Positivo**. No hay "castigos" automáticos por hacer clic; en su lugar, el error activa inmediatamente un momento de micro-aprendizaje contextual.
-

3. Proofpoint: El Análisis Basado en Amenazas Reales

Esta plataforma no opera en el vacío; se alimenta directamente de la inteligencia de amenazas de su puerta de enlace (gateway) de correo.

- **Diferenciador Técnico:** Su integración con **TAP (Targeted Attack Protection)** permite identificar a las **VAPs (Very Attacked People)**. La plataforma prioriza automáticamente el entrenamiento para aquellos usuarios que están siendo blanco de ataques reales en ese momento.
- **Enfoque de Entrenamiento:** Basado en datos. Utiliza señuelos de ataques que Proofpoint ya ha bloqueado en la vida real para entrenar a los empleados con amenazas vigentes.
- **Métricas de Medición:** **VAP Score**, un índice de vulnerabilidad que combina la frecuencia de ataque, la sofisticación del atacante y el comportamiento del usuario.
- **Control Ético:** Enfoque en la **protección del individuo de alto riesgo**, tratándolos no como eslabones débiles, sino como activos críticos que necesitan blindaje adicional.

4. Cofense: La Integración con el SOC

Cofense entiende el phishing no solo como educación, sino como una **herramienta de detección temprana**.

- **Diferenciador Técnico:** Su ecosistema conecta el **Cofense Reporter** (botón de reporte) con **Cofense Triage y Vision**. Un reporte de un usuario puede activar una búsqueda automática en todos los buzones de la empresa para eliminar correos similares en segundos.
- **Enfoque de Entrenamiento:** Acción reactiva. Entrena al usuario específicamente para que su comportamiento alimente la defensa activa de la empresa.

- **Métricas de Medición: Tasa de Resiliencia**, que es el cociente entre usuarios que reportan vs. usuarios que hacen clic.
- **Control Ético: Fomenta la Inteligencia Colectiva**. Los usuarios se sienten parte del equipo de seguridad al ver que sus reportes detienen ataques reales.

5. Phished: La Automatización de "Cero Toque"

Ideal para empresas con equipos de TI reducidos que buscan eficiencia máxima mediante IA.

- **Diferenciador Técnico: Su sistema Zero-Incident Mail™** crea simulaciones 100% autónomas. El administrador solo define el nivel de riesgo deseado y la IA se encarga de redactar, enviar y evaluar sin intervención humana.
- **Enfoque de Entrenamiento: Micro-aprendizaje invisible**. Las lecciones son tan breves y están tan integradas en el flujo de trabajo que el usuario apenas nota que está siendo entrenado.
- **Métricas de Medición: Risk Score IA**, una métrica predictiva que estima la probabilidad de una brecha de datos basada en el comportamiento histórico.
- **Control Ético: Privacidad por diseño**. Minimiza la recolección de datos personales, enfocándose únicamente en patrones de clic y reporte.

6. NINJIO: El Storytelling de Hollywood

Ninjio parte de la premisa de que los humanos olvidan datos pero recuerdan historias.

- **Diferenciador Técnico: Utiliza Perfiles de Susceptibilidad Emocional** para asignar episodios que atacan los sesgos psicológicos específicos de cada usuario (ej. urgencia, miedo, curiosidad).
- **Enfoque de Entrenamiento: Episodios animados de 4 minutos** escritos por guionistas de cine, basados en brechas de seguridad reales y recientes.
- **Métricas de Medición: Retención de Conocimiento** a largo plazo a través de cuestionarios post-episodio que miden la comprensión de la narrativa.
- **Control Ético: Apela a la seguridad personal y familiar**. Enseña al empleado cómo protegerse a sí mismo y a su familia, lo que genera una adopción voluntaria y no impuesta.

7. Mimecast: El Cambio Cultural mediante el Humor

Mimecast utiliza el humor para derribar las barreras defensivas de los empleados ante el entrenamiento aburrido.

- **Diferenciador Técnico:** Integración nativa con la **Mimecast Cloud**, lo que le permite bloquear el acceso a sitios web peligrosos en tiempo real si el usuario hace clic en una simulación o enlace real sospechoso.
- **Enfoque de Entrenamiento:** Contenido altamente humorístico (serie *Sound Advice*) para generar "conversaciones de pasillo" sobre seguridad.
- **Métricas de Medición:** **SAFE Score**, que compara el comportamiento de los empleados contra millones de puntos de datos globales de la red de Mimecast.
- **Control Ético:** Utiliza el humor para evitar el estigma del error, creando una cultura donde equivocarse en una simulación es una oportunidad de mejora, no un motivo de vergüenza.

8. Infosec IQ: La Educación Basada en Roles

Se apoya en la larga trayectoria de Infosec Institute en capacitación técnica.

- **Diferenciador Técnico: Evaluaciones Adaptativas.** Las preguntas de los exámenes cambian según las respuestas anteriores del usuario para determinar su nivel exacto de conocimiento técnico.
- **Enfoque de Entrenamiento:** Basado en roles específicos. Los desarrolladores reciben simulaciones sobre código seguro (OWASP), mientras que el personal de finanzas recibe simulaciones de fraude de facturas.
- **Métricas de Medición:** Mapeo directo contra marcos de trabajo como **NIST**, permitiendo a las empresas demostrar cumplimiento normativo con precisión.
- **Control Ético: Transparencia en el aprendizaje.** El usuario sabe exactamente qué competencias está desarrollando y cómo esto beneficia su carrera profesional.

Plataforma	Métricas	Integración	Enfoque ético	Limitaciones
Hoxhunt	Dwell Time & Resiliencia: Mide el tiempo de reacción individual y la progresión de habilidad mediante IA.	Nativa SaaS: Integración profunda con O365 y Google Workspace sin necesidad de MX records.	Refuerzo Positivo: Gamificación total; premia el reporte y elimina la sensación de "trampa".	Requiere un alto compromiso del usuario inicial para que la IA aprenda
Proofpoint	VAP Score: Identifica a las "Personas Muy Atacadas" cruzando datos de simulacros con ataques reales.	Ecosistema Cerrado: Máximo provecho si se integra con su Gateway de correo y TAP.	Protección del VAP: Ética centrada en el blindaje adicional del usuario vulnerable, no en su castigo.	Dependencia fuerte de la suite de Proofpoint para análisis profundo.
KnowBe4	PPP (Phish-Prone %): Benchmarking masivo contra la industria y métricas de cumplimiento ISO/NIST.	Abierta: APIs robustas y sincronización con Active Directory para gestión de grupos.	Transparencia: Permite anonimizar resultados de clics para cumplir con leyes de privacidad (GDPR).	Alta carga administrativa manual para gestionar la enorme biblioteca de contenido.
Cofense	Tasa de Resiliencia: Cociente entre reportes vs. clics; enfoque en la velocidad del triaje.	SOC Pipeline: Conexión directa con herramientas de análisis forense (Triage y Vision).	Inteligencia Colectiva: Empodera al usuario como "sensor" activo de la defensa de la empresa.	No es ideal para organizaciones que no tengan un equipo de respuesta a incidentes (SOC).
Phised	Risk Score IA: Predicción de probabilidad de brecha basada en comportamiento adaptativo.	API-First: Diseñada para automatización total ("set-and-forget") con mínima configuración.	Privacidad por Diseño: Recolección mínima de metadatos, centrándose solo en la acción defensiva.	Menor control manual para administradores que prefieren supervisar cada correo.
NINJO	Retención Cognitiva: Mide el aprendizaje mediante cuestionarios basados en la narrativa de los videos.	LMS & SCORM: Fácil de integrar en plataformas de aprendizaje corporativo ya existentes.	Seguridad Familiar: Ética de "Cuidado Total"; enseña a proteger la vida digital privada del empleado.	El enfoque es más educativo/teórico que de simulación técnica pura.

Mimecast	SAFE Score: Clasificación de riesgo conductual comparada con datos globales de su nube.	Cloud-Nativa: Integración con su Gateway que permite bloqueo de URLs en tiempo real.	Cultura del Humor: Usa la comedia para reducir el estigma y la ansiedad asociada a los simulacros.	Rendimiento óptimo limitado a quienes ya son clientes de su plataforma de correo.
Infosec IQ	Mapeo de NIST: Análisis directo de brechas de conocimiento según marcos de referencia globales.	RoI-Based: Segmentación técnica que permite integrarse con flujos de trabajo de ingeniería.	Transparencia Académica: El usuario sabe qué competencia está ganando, fomentando el crecimiento profesional.	La interfaz de usuario puede sentirse más rígida y menos moderna que las opciones IA.

Análisis crítico

En este análisis de 8 plataformas de simulación de phishing, se puede ver que el mercado de **Human Risk Management (HRM)** ha evolucionado bastante. Hoy en día su papel es muy amplio, ya que muchas organizaciones las consideran parte de su estrategia de defensa activa dentro de la seguridad informática.

Una primera categoría corresponde a las soluciones que trabajan con **inteligencia de amenazas**, como Proofpoint y Mimecast. Estas plataformas se apoyan en información obtenida de ataques reales que están circulando en internet para crear simulaciones o detectar intentos de fraude, pudiendo ser más reales. Gracias a esto logran un nivel alto de precisión técnica, ya que el entrenamiento se basa en amenazas reales. Sin embargo, muchas veces funcionan mejor cuando se utilizan dentro de su propio ecosistema de seguridad, lo que puede generar cierta dependencia tecnológica.

También existen plataformas que utilizan **motores de inteligencia artificial adaptativa**, como Hoxhunt y Phished. En estas soluciones el sistema analiza el comportamiento de cada usuario y ajusta automáticamente las simulaciones. Esto quiere decir que no es necesario programar manualmente las campañas, ya que la plataforma decide cuándo enviar los ejercicios y qué tipo de ataque mostrar a cada persona, ayudando así el trabajo en creación de campañas. Su principal ventaja es que reduce el trabajo operativo y permite un entrenamiento personalizado.

Por último las plataformas enfocadas en **cultura organizacional y cumplimiento**, como KnowBe4, NINJIO y Infosec IQ. En este caso el objetivo principal no es tanto la automatización, sino fortalecer la educación en ciberseguridad dentro de la empresa.

Conclusiones

Las simulaciones de phishing ya no deberían evaluarse solo por cuántas personas caen en el engaño. Más bien, lo importante es qué tan preparada queda la organización después del entrenamiento. En pocas palabras, lo que realmente importa es si los usuarios aprenden a identificar los ataques y a reportarlos más rápido. Si una plataforma logra reducir el tiempo que tarda un usuario en reportar un correo sospechoso, entonces está cumpliendo su objetivo, siempre manteniendo prácticas éticas.

Todo apunta a que el futuro del Human Risk Management está en entender que cada usuario representa un nivel de riesgo diferente. Ya no es suficiente aplicar el mismo tipo de entrenamiento para todos, ya que todos tienen criterios diferentes. La ciberseguridad actual necesita herramientas que puedan adaptarse al comportamiento de cada persona, que tomen en cuenta cómo reaccionan los usuarios ante ciertos mensajes y que, al mismo tiempo, respeten su privacidad.

CyberPress. (2026). *Best security awareness training platforms*.
<https://cyberpress.org/best-security-awareness-training-platforms/>

Hoxhunt. (2026). *Best cybersecurity training solutions*.
<https://hoxhunt.com/blog/best-cybersecurity-solutions/>

Kumar, R. (2025). *Security awareness training platforms comparison*.
<https://www.rajeshkumar.xyz/blog/security-awareness-training-platforms/>

Phished. (2026). *Top 10 security awareness training platforms in 2026*.
<https://phished.io/top-10-security-awareness-training-platforms-in-2026>

Wikipedia contributors. (2026). *Hoxhunt*. En *Wikipedia*.
<https://en.wikipedia.org/wiki/Hoxhunt>